

DPDP COMPLIANCE AUDIT

Agrivista

Digital Personal Data Protection Act 2023



Grade B

Adequate

Scanned: 25 March 2026

Files indexed: 17

Languages: express, mongoose, passport, passport-local-mongoose, ejs, ejs-mate

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user credentials (username, email, password) and profile information (number, state, city, soil nutrient levels, fertilizer, pesticide usage). The primary risk lies in the potential for unauthorized access to user accounts and the exposure of sensitive agricultural data if security measures are insufficient.

Validation Summary Rule findings: 10 confirmed, 2 false positives suppressed • AI gaps: 1 dual-validated • Score: 76 (rules) → 76 (integrated)

Total findings: 11

HIGH: 3

MEDIUM: 2

INFO: 4

Tech Stack: express, mongoose, passport, passport-local-mongoose, ejs

Risk Profile: The application collects user credentials (username, email, password) and profile information (number, state, city, soil nutrient levels, fertilizer, pesticide usage). The primary risk lies in the potential for unauthorized access to user accounts and the exposure of sensitive agricultural data if security measures are insufficient.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	0/8 (0%)	FAIL
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	0/8 (0%)	FAIL
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	2.1/6 (35%)	FAIL
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 2.0–6.8 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: passport

app.js

Flow 2: Application Logs

PII fields: passport

app.js → CropPrediction.routes.js → CropPrediction.controllers.js

Flow 3: Application Logs

PII fields: passport

app.js → CropYieldPrediction.routes.js → CropYieldPrediction.controller.js

Flow 4: Application Logs

PII fields: passport

app.js → profile.routes.js → profile.controller.js

Flow 5: Application Logs

PII fields: passport

app.js → index.js

Rule	Section	Severity	File
CONSENT_WITHDRAWAL_MISSING	Section 6(6) — Consent Withdrawal	HIGH	N/A
AUDIT_TRAIL_MISSING	Section 8(4) — Audit Trail	HIGH	N/A
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
DATA_ACCESS_MISSING	Section 11 — Right to Access	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/app.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
	Section 5 — Purpose Limitation, Section 11 — Transfer of Personal Data	MEDIUM	

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (6–20 hours)

Fix immediately — these represent the highest legal exposure.

- Consent Withdrawal Missing (1–4 hrs)
- Audit Trail Missing (4–12 hrs)
- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–14 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Data Access Missing (2–6 hrs)
- (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 14–48 hours (1.8–6.0 engineering days)

Details

Finding 1 of 11

[Section 6(6) — Consent Withdrawal]

1. [HIGH] CONSENT_WITHDRAWAL_MISSING — N / A

Estimated fix time: 1–4 hours

Consent is collected but no withdrawal mechanism detected. DPDP Section 6(6) requires consent withdrawal to be as easy as giving consent. Users must be able to revoke consent at any time.

Risk:

Failure to provide an easy consent withdrawal mechanism violates DPDP Section 6(6), potentially leading to user distrust and non-compliance penalties.

Fix:

1. Create a new API endpoint (e.g., `/consent/withdraw`) that accepts user identification and the type of consent to withdraw.
2. Implement a service function to update the user's consent status in the database, marking the specified consent as revoked.
3. Ensure this withdrawal endpoint is accessible and clearly documented for users, mirroring the ease of giving consent.
4. Add a UI element (e.g., a button or link in user settings) that triggers this withdrawal endpoint.

DPDP:

Section 6(6) — Consent Withdrawal: Requires consent withdrawal to be as easy as giving consent.

Example:

```
app.js: // In app.js or a dedicated consent router import consentRouter from
'./routes/consent.routes.js'; app.use('/consent', consentRouter); consent.routes.js: import
express from 'express'; import { withdrawConsent } from
'./controllers/consent.controller.js'; const router = express.Router();
router.post('/withdraw', withdrawConsent); export default router; consent.controller.js:
export const withdrawConsent = async (req, res) => { const { userId, consentType } = req.body;
// Logic to update consent status in DB // ... res.status(200).send('Consent withdrawn
successfully.')} };
```

Finding 2 of 11

[Section 8(4) — Audit Trail]

2. [HIGH] AUDIT_TRAIL_MISSING — N / A**Estimated fix time:** 4–12 hours

No audit trail infrastructure detected. DPDP Section 8(4) requires complete records of personal data processing activities. No access logging, audit model, or change tracking found in the codebase.

Risk:

The absence of an audit trail violates DPDP Section 8(4), hindering accountability and making it impossible to track personal data processing activities, which can lead to regulatory scrutiny.

Fix:

1. Create a new Mongoose model (e.g., `AuditLog`) to store audit events, including timestamp, user ID, action, and relevant data.
2. Implement middleware in `app.js` to capture relevant requests (e.g., data access, modification) and log them using the `AuditLog` model.
3. Modify controllers or services to explicitly log sensitive operations, such as data updates or deletions, with detailed context.
4. Develop a secure endpoint or mechanism for authorized personnel to query and review audit logs.

DPDP:

Section 8(4) — Audit Trail: Requires complete records of personal data processing activities.

Example:

```
models/AuditLog.model.js: import mongoose from 'mongoose'; const auditLogSchema = new
mongoose.Schema({ timestamp: { type: Date, default: Date.now }, userId: { type:
mongoose.Schema.Types.ObjectId, ref: 'User' }, action: String, details: Object }); export
default mongoose.model('AuditLog', auditLogSchema); // In app.js or middleware: // import
AuditLog from './models/AuditLog.model.js'; // app.use(async (req, res, next) => { // await
AuditLog.create({ userId: req.user?._id, action: `${req.method} ${req.originalUrl}` }); //
next(); // });
```

Finding 3 of 11

[Section 13 — Grievance Redressal]

3. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A**Estimated fix time:** 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

Failing to publish contact details for a grievance officer or DPO contravenes DPDP Section 13, leaving data subjects without a clear channel to raise concerns and potentially delaying resolution of privacy complaints.

Fix:

1. Create a new route (e.g., `/grievance` or `/contact-dpo`) in `app.js` to serve a page with grievance redressal information.
2. Add a dedicated contact email address for grievance handling to your application's configuration (e.g., `.env` file).
3. Update the new grievance route's controller to display the contact email and any other required information as per DPDP guidelines.
4. Ensure this grievance route is easily discoverable by users, for example, via a link in the website footer.

DPDP:

Section 13 — Grievance Redressal: Requires a mechanism for data subjects to address grievances.

Example:

```
app.js: // Add this line to import and use the new route import grievanceRouter from
'./routes/grievance.routes.js'; app.use('/', grievanceRouter); // Or another appropriate base
path grievance.routes.js: import express from 'express'; import { getGrievanceInfo } from
'../controllers/grievance.controller.js'; const router = express.Router();
router.get('/grievance', getGrievanceInfo); export default router; grievance.controller.js:
export const getGrievanceInfo = (req, res) => { const dpoEmail = process.env.DPO_EMAIL ||
'dpo@example.com'; res.render('grievance.ejs', { dpoEmail }); };
```

Finding 4 of 11

[Section 11 — Right to Access]

4. [MEDIUM] DATA_ACCESS_MISSING — N / A**Estimated fix time:** 2–6 hours

No endpoint detected that allows authenticated users to retrieve their own personal data. Under DPDP Section 11, Data Principals have the right to access information about their personal data being processed.

Risk:

The lack of data access controls and logging means unauthorized access to personal data could go undetected, violating DPDP principles of data minimization and security, and hindering accountability.

Fix:

1. Implement role-based access control (RBAC) middleware to restrict access to sensitive data based on user roles.
2. Integrate a logging library (e.g., Winston, Pino) to record all access attempts to personal data, including user ID, timestamp, and data accessed.
3. Review and refactor data access logic in controllers and services to enforce the newly implemented RBAC policies.
4. Ensure logs are stored securely and are only accessible by authorized personnel for auditing purposes.

DPDP:

Section 8(1) — Data Security: Requires appropriate technical and organizational measures to protect personal data.

Example:

```
middleware/auth.middleware.js: export const requireAuth = (req, res, next) => { if
(!req.isAuthenticated()) { return res.redirect('/login'); } next(); }; // In routes: //
router.get('/profile', requireAuth, (req, res) => { /* access profile data */ }); // Example
logging (using a hypothetical logger): // import logger from '../utils/logger.js'; //
router.get('/sensitive-data', requireAuth, (req, res) => { // logger.info(`User ${req.user.id}
accessed sensitive data.`); // // ... fetch data // });
```

Finding 5 of 11

[Section 8(6) — Breach]

5. [LOW] NO_BREACH_ALERTING — N / A**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a breach notification mechanism means that if a data breach occurs, affected individuals and the Data Protection Authority will not be promptly informed, potentially leading to regulatory penalties and loss of trust.

Fix:

1. Integrate a monitoring and alerting service (e.g., Sentry, Datadog) to detect and notify on security incidents.
2. Create a dedicated route or controller function to handle security breach events.
3. Implement logic within the breach handler to identify affected data subjects and trigger notifications.
4. Configure an escalation policy to alert a designated compliance team or individual upon breach detection.

DPDP:

Section 8(6) — requires notification to affected individuals and the Authority without undue delay when a personal data breach occurs.

Example:

```
import * as Sentry from '@sentry/node'; // Initialize Sentry SDK
Sentry.init({ dsn: process.env.SENTRY_DSN, integrations: [ new Sentry.Integrations.Express({ app }), ], }); //
Example of triggering a custom event for a potential breach function
triggerBreachAlert(breachDetails) { Sentry.captureException(new Error(`Data Breach Detected:
${breachDetails}`)); }
```

Finding 6 of 11

[Section 11 — Data Portability]

6. [LOW] DATA_PORTABILITY_MISSING — N / A:15

Evidence snippet: This controller fetches user profile data but does not offer an option to export it.

Estimated fix time: 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The lack of a data portability feature prevents users from accessing and transferring their personal data in a usable format, which is a requirement under DPDP Section 11 and hinders user control over their information.

Fix:

1. Create a new API endpoint (e.g., GET /api/v1/user/data) to handle data portability requests.
2. In the corresponding controller, fetch all personal data associated with the authenticated user (e.g., from Profile and User models).
3. Format the retrieved data into a commonly used, machine-readable format such as JSON or CSV.
4. Set appropriate response headers (e.g., 'Content-Disposition: attachment; filename="userdata.json"') to prompt file download.

DPDP:

Section 11 — requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Example:

```
import express from 'express'; import User from '../models/user.model.js'; // Assuming you have a User model
import Profile from '../models/profile.model.js'; // Assuming you have a Profile model
const dataPortabilityRouter = express.Router();
dataPortabilityRouter.get('/user/data', async (req, res) => { try { const userId = req.user._id; // Assuming user is authenticated via passport
const user = await User.findById(userId).lean(); const profile = await Profile.findOne({ owner: userId }).lean();
const userData = { user, profile }; // Combine relevant data
res.json(userData); // Respond with JSON } catch (error) { res.status(500).send('Error exporting data'); } });
export default dataPortabilityRouter;
```

Finding 7 of 11

[Section 7 — Legitimate Use]

7. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / app.js

Internal file (app.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 8 of 11

[Section 5 — Notice]

8. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 9 of 11

[Section 5 — Purpose Limitation]

9. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 10 of 11

[Section 16 — Cross-Border Transfer]

10. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 11 of 11

[Section 5 — Purpose Limitation, Section 11 — Transfer of Personal Data]

11. [MEDIUM] — CODEBASE-WIDE

PII shared with external APIs without explicit consent

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] PII shared with external APIs without explicit consent

Confidence: 71%

Section 5 — Purpose Limitation, Section 11 — Transfer of Personal Data

The ``data_flows`` indicate that profile-linked agricultural data (e.g., State, city, N, P, K, Fertilizer, Pesticide from ``src/models/profile.model.js``) is sent to external APIs via ``POST /predict`` and ``POST /predict-crop`` (handled by ``src/controllers/CropYeildPrediction.controller.js`` and ``src/controllers/CropPrediction.controllers.js``). The rule engine noted ``third_party_checked: false``, indicating a lack of scrutiny over third-party data sharing.

Recommendation: In ``src/controllers/CropYeildPrediction.controller.js`` and ``src/controllers/CropPrediction.controllers.js``, ensure explicit, informed consent is obtained from the user **before** sending their profile-linked agricultural data to external APIs. Additionally, establish Data Protection Agreements (DPAs) with these third-party API providers.

Deep Compliance Review

Overall Risk: CRITICAL

The application exhibits critical DPDP compliance gaps, primarily due to the absence of explicit user consent mechanisms for PII collection and sharing with third parties. Significant risks exist in data minimization, inadequate PII identification, and protection across data storage, API routes, and session management. These systemic issues increase the likelihood of unauthorized data disclosure and regulatory non-compliance, demanding immediate architectural and code-level remediation.

Expected Remediation Timeline: 30 Days

Most Critical Action: Implement explicit user consent mechanisms for PII collection and third-party sharing, ensuring consent status is stored and enforced across all data processing activities.

Layer Breakdown

Third-Party & PII Flows — 2 finding(s). This layer handles user authentication and registration. Key DPDP compliance gaps include the absence of explicit consent mechanisms for PII collection during signup and the risk of sensitive data exposure through unsanitized error messages. Addressing these issues is crucial for lawful processing and data security.

API Routes & Controllers — 3 finding(s). The API Routes & Controllers layer exhibits significant DPDP compliance risks, primarily concerning the sharing of user-generated data with third-party services without explicit consent or proper data processing agreements. Additionally, there are concerns regarding data minimization during profile retrieval and the potential for PII exposure in error logging. Addressing these issues is crucial for adherence to DPDP principles.

Data Models & Storage — 3 finding(s). The data models lack explicit mechanisms for enforcing data retention limits and storing consent status, which are critical for DPDP compliance. Additionally, PII fields are not adequately identified or protected within the schema definitions, posing a risk to data security and accountability.

Authentication & Session — 4 finding(s). The Authentication & Session layer demonstrates common middleware patterns but introduces DPDP risks through insufficient data minimization and storage limitation practices for redirect URLs. Additionally, the robustness of the authentication check and middleware chaining could be improved to enhance the reliability and auditability of security controls.